Contents

Volume 05 — Regulation, Economics, Strategy, Capstone **1**
Lecture T30: Privacy Regulation — Part 01 1
Lecture T31: Privacy Regulation — Part 02 3
Lecture T32: Privacy Regulation — Part 03 5
Lecture T33: GDPR — Part 02 6
Lecture T34: GDPR — Part 03 8
Lecture T35: Privacy: The Indian Way — Part 01 9
Lecture T36: Privacy: The Indian Way — Part 02 11
Lecture T37: Privacy: The Indian Way — Part 03 12
Lecture T38: GDPR — Part 01 14
Lecture T39: Information Privacy — Economics and Strategy — Part 01 15
Lecture T40: Information Privacy — Economics and Strategy — Part 02 16
Lecture T41: Information Privacy — Economics and Strategy — Part 03 18
Lecture T42: Privacy — Strategy and Safety — Part 01 19
Lecture T43: Privacy — Strategy and Safety — Part 02 20
Lecture T44: Privacy — Strategy and Safety — Part 03 21
Lecture T45: Cyber Security and Privacy — Capstone Discussion A 23
Lecture T46: Cyber Security and Privacy — Capstone Discussion B 24

Volume 05 — Regulation, Economics, Strategy, Capstone

Cyber Security and Privacy · NPTEL 106106248 · Prof. Saji K. Mathew **notes-3** — concept exam notes (definitions & what things do). Breadth over lab depth.

Lecture T30: Privacy Regulation — Part 01

Learning focus

- Explain why privacy concern, once it is collective, becomes a regulatory problem for the state.
- Show how platform **lock-in**, unread privacy clauses, and immediate gratification produce one-sided data exchanges.
- Define the **privacy paradox** as the clash between wanting a personalised experience and wanting privacy.
- Distinguish **right to privacy** from **right to anonymity**, using Derek Smith / ChoicePoint.
- Separate **personal data**, **personally identifiable information (PII)**, and **quasi-identifiers**.

Key terms

Term	Meaning in this lecture
Lock-in	Enter a product/service and cannot leave; switching cost prohibits exit. Built into platform strategy.
Switching cost	Cost of moving to another product or service; when high, you stay.
Immediate gratification	Economist's name for rushing to the service and clicking agree without reading.
Non-monetary exchange	You pay with data, not money; still an exchange (no free lunch).
Right to be let alone	Classic privacy formula — which most people do not actually want, because they want to socialise.
Selective disclosure	Choosing what a profile shows in order to make an impression.
Privacy paradox	Wanting both the best personalised/free service and privacy; the two conflict.
Right to privacy vs anonymity	Privacy is not invisibility; Smith: you cannot have a right to anonymity in this society.
Personal data	Any data that is yours and related to you.
PII / identifiable data	Attributes that uniquely or partly identify you.
Quasi-identifier	Not unique alone (e.g. name); combining several can identify.

Frameworks / formulas

- **Regulation warrant:** individual concern → collective/pervasive breach → citizen-data held by industry → government welfare role → regulate.
- **Unfair consent stack:** lock-in + unread legal text + immediate gratification + one-sided click-wrap → need for regulation (GDPR later).
- **PII construction:** quasi-identifiers + linking ≈ identification.

Distinctions

- Cybersecurity and information privacy share concepts, but privacy concern is its own domain — how well you address it is the privacy problem.
- Lock-in is not mere preference; it is a designed platform strategy (Hotel California).
- "Free" digital service is not free; it is a non-monetary data exchange, which is why court challenges fail once you clicked agree.
- Privacy agreements are one-sided **by design**; fairness, not just individual carelessness, is the regulatory issue.
- Very few people want to be let alone; the social need and selective disclosure are why platforms harvest so much.
- You raise privacy concerns when the **trade of data affects you**, not when you take the discount — that is the paradox.
- **Right to privacy ≠ right to anonymity.** You cannot be anonymous on the planet and still claim the privileges of a state.
- Name is personal data and a quasi-identifier; it is not, by itself, a unique identifier.

Exam lines

- Regulation is needed because breaches are pervasive, organisations store citizen data, and government's job is welfare.
- Platforms lock users in; privacy policies take ~76 working days to understand; click-wrap is not fair play.
- Privacy paradox: personalised experience vs privacy; both are wanted, both cannot be fully had.
- Mandatory state disclosure is the harder case of the same tension.
- ChoicePoint/Smith: privacy yes, anonymity no.
- Personal data vs PII vs quasi-identifiers; linking can finish the identification GDPR will later regulate.

Lecture T31: Privacy Regulation — Part 02

Learning focus

- Separate **anonymity, secrecy, confidentiality, transparency, privacy, and security**, which the instructor says are often confused.
- Place total anonymity, **pseudo-anonymity**, and identifiability on one scale, including Aadhaar's pseudo identifier.
- Apply three privacy-preserving data-mining techniques: **randomization, anonymization, encryption**.
- State **k-anonymity** (Sweeney), and distinguish **suppression** from **generalization**.
- Use the **risk–utility (R–U) map** as the analytics trade-off that regulation must govern.
- Contrast US sectoral law, FIPPs/OECD principles, the EU **directive**, and the 2018 EU **regulation**.

Key terms

Term	Meaning in this lecture
Anonymity	Ability to conceal identity; share facts that cannot be accurately linked to you.
Pseudo-anonymity	Substitute ID (Aadhaar-issued) that an agency can map back; business cannot. Not pure anonymity.
Secrecy	Intentional concealment; may mislead; low volume and low accuracy.
Confidentiality	Limited sharing; when shared, complete and identified. Organisational word.
Privacy	Typically the individual-level counterpart of confidentiality.
Transparency	High accuracy and high volume shared (public institutions).
Randomization	Share $x_i + e_i$, not x_i; processor sees noise / distribution, not exact values.
k-anonymity	Every quasi-identifier combination matches at least k people.
Suppression	Remove a column entirely.

Term	Meaning in this lecture
Generalization	Coarsen (year not full DOB; truncated zip; last-4 of Aadhaar).
Linking	Re-identify anonymized records by joining more data.
R–U map	Trade-off of disclosure **risk** vs data **utility**.
Directive vs regulation	EU pre-2018 D = not enforceable as such; 2018 R = law.
FIPPs	US Fair Information Practice Principles — principles, not a statute.

Frameworks / formulas

- **Randomization:** processor receives $x_i + e_i$, e_i random noise from some distribution.
- **k-anonymity:** each released quasi-identifier tuple is indistinctly matched to ≥ k individuals; k is the extent of anonymization.
- **2×2:** accuracy × amount shared → secrecy / anonymity / confidentiality / transparency.
- **R–U:** more disclosure → more risk and more utility; regulation is choosing the operating point for a country.

Distinctions

- Pseudo-anonymity is **not** pure anonymity: Aadhaar (or another agency) can reconstruct.
- Grade / a fact-table **measure** is not PII; name, roll, email are.
- Confidentiality ≠ privacy (organisation vs individual, in the literature used here).
- Secrecy is not anonymity: secrecy can be inaccurate and misleading; anonymity can share a lot of true facts without a link.
- Incognito hides the **local machine**, not the service provider.
- Suppression is dropping a column; showing last-4 digits is **generalization**.
- FIPPs and the old EU instrument are **not** regulations; HIPAA is domain-specific; the US has **no omnibus** personal-data law; GDPR is the broad template.

Exam lines

- Four-quadrant map is the clean way to keep secrecy, anonymity, confidentiality, and transparency apart.
- PPDM: randomize, anonymize, or encrypt before a processor sees data.
- k-anonymity + suppression + generalization; linking is why they are not enough.
- Last-4 Aadhaar is generalization.
- R–U: personalisation needs identity; privacy needs blur; regulation governs the middle.
- 2018: EU directive becomes regulation. US remains sectoral and state-wise — which the Equifax case will show as a limitation.

Lecture T32: Privacy Regulation — Part 03

Learning focus

- Reconstruct the **Equifax 2017** breach: business model, unpatched **Apache Struts**, stolen PII, delayed disclosure.
- List privacy harms of a credit-bureau leak (identity theft, loan fraud, targeting, Aadhaar-scale analog in India).
- Separate **technical** failures (patch, SSL, logs, ACIS) from **governance** failures (CLO over CSO, board silence on public cyber ratings).
- Follow the class debate: **negligence vs unlucky**, then the instructor's question — where is the **major** problem?
- State why **breach-notification timelines** (US patchwork vs later GDPR **72 hours**) are the regulatory lesson.

Key terms

Term	Meaning in this lecture
GTVM / VAT / Countermeasures	Equifax threat-tracking, scanning, and blocking functions that still failed.
Apache Struts	Open-source Java web framework; public exploit was the entry.
Web shell / backdoor	~30 persistence paths Equifax did not see.
ACIS	Old (class: 1970s) control that blocked one IP and could not see the rest.
File-integrity monitoring	Missing control: scan for unauthorised access / suspicious events.
Credit freeze	Lock the file so new credit cannot be opened — Equifax charged for it after the breach.
Clawback	Recovering executive pay after failure.
Breach notification	Duty to tell people and regulators in a fixed time so they can act.
CCC / FICO cyber	Public cyber ratings the board could have interrogated and did not.

Frameworks / formulas

- **Two-chain model:** security says what; technology deploys; CEO must actually integrate them.
- **Notification comparison taught here:** US mix of 45 days / none → proposed **30-day** consumer notice; NY **72 hours** to regulators; GDPR (preview) **72 hours**.
- **Governance test:** did the board have independent, public evidence (audit, MSCI, CERT) and fail to ask?

Distinctions

- Investment and a CSO on the org chart ≠ security. Equifax spent >1% of revenue and still failed.
- **Post-hoc** blame is easy; still, the **major** documented failure is **corporate governance**, not "Equifax was unlucky."
- Board fault is not micromanaging patches; it is **not reacting to information it had** (2015 audit, public CCC).
- CLO presenting cyber without cyber competence is a structural, not a personality, problem.
- Cybersecurity at this scale is **enterprise risk / governance**, not only IT.
- Delayed disclosure is not a PR issue only: without a legal clock, **the individual cannot freeze credit**. That is why regulation must specify days.
- Equifax is a **data business** and a **high-value target**; "attacks happen every day" is not an excuse.

Exam lines

- Vector: unpatched Apache Struts after a public CERT alert; persistence via web shells; expired SSL; 8,500 leftover vulns.
- 143 million Americans (~half of adults); SSN-level PII.
- Disclosure ~six weeks after discovery; no US-wide rule.
- Root cause the class is meant to leave with: **governance** (board + split IT/security under a non-expert CLO) plus **no mandatory notification**.
- Bridge to Europe: GDPR puts the 72-hour clock and processor/controller accountability into law.

Lecture T33: GDPR — Part 02

Learning focus

- Attribute GDPR's foundation, as the lecture does, to **Ann Cavoukian** and her **privacy by design / by default** line.
- Turn GDPR into organisational work: **records, DPIA, 72-hour notice, DPO, vendor contracts, third-country safeguards**.
- Explain why **COVID / hybrid work** is used to account for the surge in fines.
- State the lecture's "way forward": privacy as **new normal** and **brand differentiator** (~120 country laws; 82% see certifications as a buying factor).
- Take the implementation Q&A seriously: culture, manufacturing capability, import leverage, and **aware people** plug loopholes more than text does.

Key terms

Term	Meaning in this lecture
Privacy by design	Embed protection at conceptual/design stage, not after go-live.

Term	Meaning in this lecture
Privacy by default	Settings protect the user without extra action; full functionality, not a trade-off.
Positive-sum	Cavoukian: not “some privacy vs some function.”
SCC / BCR	Standard contractual clauses / binding corporate rules when the destination lacks adequacy.
Demonstrate adherence	Accountability is not only doing; it is showing (certification).
SASE / hybrid	Remote work makes GDPR compliance “hectic”; security protocols must follow the user.
Privacy as differentiator	Certification / shield as a **buying factor** (82%).

Frameworks / formulas

- **Cavoukian seven** (as taught): full functionality, end-to-end, transparency, user-centricity, proactive, embedded design, default.
- **Post-breach triad:** 72h to authority + notify individuals + technical/organisational detect-report-investigate.
- **Third-country fork:** adequacy-like protection **or** SCCs/BCRs/contracts.
- **Fine trajectory they cited:** min €2,000; 306 (2020) → 429 (2021); seven-fold money, blamed on COVID attack surface.

Distinctions

- Privacy in the product is **not an afterthought** and not a zero-sum against functionality.
- 72 hours is not only “tell the regulator”; **tell the person**.
- Strength of controls **scales with sensitivity** — medical/legal data is not a cookie banner.
- Processors outside the EU (India included) are in via **contract**, not via geography.
- More fines in 2020–21 are taught as **WFH unpreparedness**, not only “evil Big Tech.”
- Exporting to the EU buys **leverage for EU rules**; importing does not. India’s 5% idea does not erase that.
- Implementation gaps close with **educated users**, not only with stricter text.

Exam lines

- Lecture founder figure: Cavoukian; slogans: no borders; by design; by default; positive-sum.
- Operations: processing records, breach logs, DPIA on new processing, DPO, 72h + individual notice, SCCs/BCRs for India-like destinations.
- Privacy is becoming a market factor (82%) and a global template (~120 laws).
- The hard part, in Q&A, is **implementation** given culture, industrial capability, and awareness — not drafting another article.

Lecture T34: GDPR — Part 03

Learning focus

- Argue both sides: GDPR as **accountability** (Equifax lesson) vs GDPR as a **constraint on data-driven business models**.
- Explain **privacy by default as a nudge** (default radio button = I disagree).
- Show why **cookie banners** may not produce real consent (gratification, no time to read).
- Map **third countries** and the lecture's **14 "secure" / expressly permitted** countries — **USA and India not on the list**.
- Apply GDPR to **IIT Madras**: EU exchange and joint-degree data, MOUs without privacy clauses, photo consent at Passau.

Key terms

Term	Meaning in this lecture
Downside of GDPR	May stifle ad-funded, data-native business models.
Accountability	Equifax hole GDPR fills: who is liable, what penalty, when to report — collectors **and** processors.
Nudge	Default option steers choice; privacy-by-default = default **disagree**.
Cookie consent	Post-2018 banners; lecture conclusion: does **not practically work** as informed consent.
Harmonisation	GDPR is a regulation, uniform for members; unlike DPD.
Third country	Non-EU destination; India is one.
Expressly permitted / 14	Countries treated as safe for free transfer; **not** US, **not** India.
MOU	The contract through which a university relationship should (but often does not) carry GDPR duties.

Frameworks / formulas

- **Balance:** accountability and no-abuse **versus** not killing data businesses; privacy is not absolute.
- **Default test:** radio button on signup = disagree if you are serious about privacy-by-default.
- **Transfer test:** on the 14-list → express permission; else **specific contracts**.
- **University test:** do we store EU persons' data? Then GDPR awareness is not optional, complaint or no complaint.

Distinctions

- "Do business without personal data" is too simple; **stricter law does stifle** some models — and **no law** enables Equifax-style unaccountability and platform misuse.
- Privacy is **not absolute**; people will share; they refuse **abuse**.
- Privacy by default is a **nudge**, not a moral sermon.

- Cookie banners are **compliance theatre** if nobody can read them — same immediate-gratification problem as T30's 76-day privacy policy.
- GDPR is **harmonised for members**; remaining differences (Ireland/Netherlands) are not a licence to shop for a blind regulator.
- Adequacy is **political/legal**, not "USA is advanced so it must be on the list."
- IIT is not outside GDPR because it is Indian; **EU student data** is enough. Informal Indian breach culture is **not** the European standard (Passau photos).
- Wanting Indian law to be "very strict" and then complaining about lost opportunities is the same flip the next India lectures will hit.

Exam lines

- GDPR's teeth (fines, 72h, processor liability) are the point of Equifax; the cost is pressure on ad-tech models.
- Default-disagree and privacy-by-design are the innovative ideas; banners mostly fail the human-time test.
- India and the US are **third countries**, not on the 14; contracts must carry GDPR.
- IIT Madras already processes EU data (exchanges, joint degrees); MOUs and photo practice are the awareness gap.
- Next: Indian constitutional privacy, Puttaswamy, Aadhaar, DPDP.

Lecture T35: Privacy: The Indian Way — Part 01

Learning focus

- Read **Article 21** as personal liberty **with** the clause "except according to procedure established by law."
- Place the **Indian Telegraph Act 1885** (and **1972** amendment) beside that liberty: the state has interceptive rights.
- Name **Justice K.S. Puttaswamy** as the lecture's "father of data privacy in India" and state the **24 August 2017** holding.
- Apply the **threefold test** (legality, need / legitimate state aim, proportionality).
- Trace **Srikrishna → PDP bill dropped → DPDP 22 bill**, in parallel with GDPR 2018.
- Hold both lines: privacy is a **fundamental right** and **not absolute**; the state has **no absolute power to snoop**.

Key terms

Term	Meaning in this lecture
Article 21	Life and personal liberty except by procedure established by law.
Indian Telegraph Act 1885	Colonial intercept statute; still the legal spine of tapping.
1972 amendment	Emergency-period expansion of wiretap, including opposition.

Term	Meaning in this lecture
Data fiduciary (here)	Government as custodian of 1.3B Aadhaar records.
K.S. Puttaswamy	2012 PIL; “father of data privacy in India.”
Inner sphere / autonomy	Core of the 24 Aug 2017 holding; state **and** non-state actors.
Srikrishna Commission	Expert draft of PDP after consultations, GDPR-aware.
PDP	2018 Personal Data Protection bill; government altered; Parliament stalled; **dropped**.
DPDP 22	Digital Personal Data Protection bill that replaced it (still a bill in this lecture).
Threefold test	Legality, legitimate aim, proportionality.

Frameworks / formulas

- **Art. 21 structure:** liberty **+** “except according to procedure established by law.”
- **Puttaswamy formula:** fundamental right protecting inner sphere from state and non-state interference → autonomous life choices.
- **Snoop test:** no intercept without legality + need + proportional collection.
- **Two parallel lines:** welfare / unique ID **vs** autonomy to refuse biometrics → **regulation**.

Distinctions

- Do not quote Article 21 without the **exception**.
- Telegraph Act and Article 21 **coexist**; conflict is structural, not an accident.
- He **mis-speaks 2018**, then pins the judgment at **24 August 2017** — use the corrected date.
- Puttaswamy is not a slogan; it is a **writ** the Court had to decide.
- Government, not Facebook, is India’s **largest** personal-data controller.
- Mandatory Aadhaar-for-benefits vs fundamental privacy is a **grey area**, not a one-line win for either side.
- End use (fraud reduction in Assam) is relevant **and** there is **no guarantee** against compromise — hence a statute.
- Majority-benefit vs elite-privacy is the **privacy paradox** again, not proof that rights do not matter.

Exam lines

- 1885 intercept + 1950 Art. 21 + 1972 tap + 2012 PIL + **24 Aug 2017** fundamental right + 2018 PDP + dropped + **DPDP 22**.
- Father of Indian data privacy in this course: **Puttaswamy**.
- Three tests for invasion; ~10 agencies still sit on the Telegraph Act.
- Aadhaar made the state the main fiduciary; that is why privacy had to be constitutionalised.
- Next lecture: Aadhaar Act, Nilekani, architecture, weak links.

Lecture T36: Privacy: The Indian Way — Part 02

Learning focus

- Show that Aadhaar collection is **"according to procedure established by law"** because there was an **Aadhaar Act** first.
- Explain the **welfare / anti-leakage** rationale: multiple identities, **₹1 → 70 paise**, information asymmetry (IRCTC).
- Describe Aadhaar as a **12-digit platform** run by **UIDAI**, designed by **Nandan Nilekani**, with a **minimalist** collection claim.
- Map **CIDR / ASA / AUA / device / user** and the **yes/no** authentication design.
- Locate **weak links**: enrolment vendors, disclosed Aadhaar numbers, **linking**, the "10-foot wall" vs Keshav's open back door.
- Note Supreme Court **limits on mandatory Aadhaar** and the still-open **DPDP** debate on how safe the database is.

Key terms

Term	Meaning in this lecture
UIDAI	Statutory authority for Aadhaar collection and database.
Aadhaar Act	The "procedure established by law" that makes collection legal.
Leakage	Share of welfare rupee that does not reach the target (here 30 paise).
Platform (Aadhaar)	Base database on which many participant-types connect and build.
Minimalist collection	Only basic identification data, not full demographics — Nilekani claim.
CIDR	Core identities repository behind the data-centre wall.
ASA	Enlisted technical path to CIDR (BSNL, NIC, telcos).
AUA	Face-to-face service agency (bank, telco, passport).
Yes/no authentication	AUA does not receive the biometric payload; only match result.
Weakest link	Cartoon/chain: not the wall; vendors, numbers, other websites.
Pseudo ID / VID idea	Substitute number so the raw Aadhaar is not left with every AUA.

Frameworks / formulas

- **Art. 21 applied:** Aadhaar Act ⇒ legality of collection is settled; **use, mandate, and security** remain open.
- **Leakage identity:** multiple IDs ⇒ ₹1 welfare → 70 paise; unique biometric ID is the state's efficiency answer.
- **Layered access:** User → device → AUA → ASA → CIDR; compare to T31's processor chain.
- **Weak-link audit:** core encryption ≠ no leak if collection vendors and downstream number-holders are open.

Distinctions

- **Legal** collection (Aadhaar Act) does not answer **mandatory use** or **security of the chain**.
- Party politics is the wrong frame; **every** government digitised; Nilekani had to work **across** parties.
- Aadhaar as **platform** is a design claim (orchestration), not "just a government file."
- **Minimal data at collection** is the official theory; **thousands of vendors** are the practice.
- Supreme Court: Aadhaar not mandatory for all **fundamental** services; **SIM** still requires it in this lecture's India.
- Gulshan Rai's wall is **physical security rhetoric**; Keshav's back door is the analytical point.
- He will **not** assert a proven leak **from CIDR**; he **will** assert vendor firing and public web dumps of numbers collected elsewhere.
- Authentication **yes/no** protects biometrics in transit **and** still leaves the **12-digit ID** and **linking** problem — same quasi-identifier logic as T31.

Exam lines

- Aadhaar is lawful (the Act), welfare-rational (70 paise, multiple IDs), and a Nilekani **platform** with a 12-digit unique key.
- Architecture: CIDR behind ASA/AUA; telcos are both.
- Risk is the **chain**: enrolment vendors (~1,000 fired), Aadhaar numbers sitting with AUAs and other websites, linking/profiling; pseudo-ID is the taught mitigation.
- SC cabined mandatory use; SIM/banking still pull the ID.
- "100% secure / 10-foot wall" fails the weakest-link test the cartoon and the IIT Delhi paper (in Srikrishna) were assigned to teach.

Lecture T37: Privacy: The Indian Way — Part 03

Learning focus

- State the government's terms of reference for the Justice Srikrishna Commission and why they put the data economy first.
- Map the three data actors in PDP/DPDP against GDPR language.
- Compare the Personal Data Protection (PDP) draft with the Digital Personal Data Protection (DPDP) bill as taught in class.
- Argue both sides of data localisation, including cost, jurisdiction, jobs, and corporate power.

Key terms

Term	Meaning in this lecture
Data principal	Individual whose data is collected (GDPR data subject)
Data fiduciary	Controller: collects, stores, decides sharing and processing; "guardian" of data

Term	Meaning in this lecture
Data processor	Party that only processes data shared by the fiduciary
SPD	Sensitive personal data — health, financial, passwords, matrimonial/preference data
CPD	Critical personal data — undefined in PDP; government could designate it; meant for in-country storage
Data localisation / residency / sovereignty	Citizens' data stored inside the country so Indian law still applies
Right to erasure	DPDP substitute for PDP's right to be forgotten; may not cover onward sharing
Rule-making power	Central government can make rules under ~14 of DPDP's 22 clauses
Conflict of interest	Government as large fiduciary **and** rule-maker

Distinctions

- Unlocking the **data economy** is first in the TOR; privacy is to be upheld **without destroying data businesses**.
- **Fiduciary ≠ processor.** Analytics vendors process; they do not decide collection and sharing.
- **Right to be forgotten ≠ right to erasure** if sharing among entities is the issue.
- **Legal jurisdiction follows the data.** Once data is in country X, Indian PDP/DPDP cannot simply follow it.
- Localisation is not only a privacy slogan; it is a fight among **state control, corporate cost, and jobs**. DPDP's dilution is taught as **corporate interest**, not as simple "privacy loss."
- Government need for access is **legitimate**; combining **fiduciary + regulator** is the conflict, not the need itself.
- Srikrishna's "Orwellian" remark is about **the amended bill**, not the original draft, and is not to be reduced to party politics.

Exam lines

- TOR: unlock data economy **and** protect citizen data — economy named first.
- PDP 2019: Cabinet bill with extra **government access** powers; Srikrishna disowns it; bill dropped.
- DPDP 2022: 6 chapters / 24 pages vs PDP 14 / 56; PII only; 22 clauses; government rules in ~14; penalty cap **₹500 crore**; principals can be fined for false claims.
- Actors: principal, fiduciary (Aadhaar), processor; GDPR-style contracts and processor liability.
- PDP three-tier data (personal / SPD / CPD) and strict localisation of SPD+CPD **removed** in DPDP.
- Localisation plus/minus: jurisdiction and Indian analytics vs DC cost, scale, few jobs, corporate non-competitiveness.

- Next theme already announced: if privacy law makes data as expensive as scarce oil, data businesses die.

Lecture T38: GDPR — Part 01

Learning focus

- Restate the **need for regulation** as a fair balance among data collectors, processors, and individuals.
- Contrast US **sectoral / toothless** law (Equifax notification gap, no set penalty) with the EU move from **1995 DPD** to **GDPR 2018**.
- Define GDPR **personal data** (direct and in-conjunction identifiers).
- List the **six principles**, **six legal bases**, **controller / processor / DPO** roles, and **data-subject rights**.
- State the fine: **€20 million or 4% of global annual revenue, whichever is higher**, and 72-hour breach notice.

Key terms

Term	Meaning in this lecture
DPD (1995)	Directive: member states write their own laws; not uniform.
GDPR	Regulation: law, enforced 2018 (adopted 2016).
Personal data	Identifies on its own **or in conjunction** (IP, device ID, geo, biometrics).
Controller	Decides purposes and means.
Processor	Processes on behalf; now jointly liable; needs a contract.
Pseudonymization	Replace original with artificial data.
DPO	Mandatory central contact for GDPR compliance.
DPIA	Project-specific high-risk impact assessment; privacy by design.
72 hours	Uniform breach notification window under GDPR.
4% / €20M	Ceiling on administrative fine, higher of the two.

Frameworks / formulas

- **Scope test:** EU establishment **or** processing of people residing in the EU.
- **Lawful processing:** one of six bases; not “because we want the data.”
- **Accountability pair:** controller **and** processor; DPO; DPIA for high risk; 72h notice; 4% / €20M.

Exam lines

- GDPR applies to anyone processing EU residents’ data, not only EU companies.
- Six principles (lawfulness/fairness/transparency through CIA) and six legal bases (consent through legitimate interest).
- Roles: subject, controller, processor, DPO; mermaid above.
- Rights: access, know, rectify, erase, restrict, port, object.

- Uniform 72-hour breach notice and 4% / €20M fines are the “teeth” the US cases lacked.

Lecture T39: Information Privacy — Economics and Strategy — Part 01

Learning focus

- Explain why privacy must have an **economic value** if businesses are to spend on it.
- Show why cloud/controller–processor **contracts** still use thumb rules instead of a valuation model.
- Run the Gmail classroom experiment as **WTP vs WTA** and name that gap the **privacy paradox**.
- Apply **loss aversion**, **endowment effect**, and **stated vs revealed preference** to privacy pricing.

Key terms

Term	Meaning in this lecture
Valuation of privacy	Assigning economic value to PII databases so contracts can set breach penalties
Thumb rule	Industry substitute for a model — here **5% of contract value**
WTP	Willingness to pay to **protect** privacy (tends low)
WTA	Willingness to accept money to **give up** privacy (tends high)
Privacy paradox	Advocate privacy in talk; cheap to buy protection, expensive to sell it
Loss aversion	Pain of loss weighted above equivalent gain; prospect theory
Endowment effect	Extra value because the thing is already yours; parting pain
Privacy calculus	Mental trade-off when deciding about privacy
Stated preference	What you say in a survey
Revealed preference	What you do in a game or in the market
Contingent valuation	Economist’s tool using those two preference types

Distinctions

- Privacy without **economic or strategic** implication is not a business topic.
- **Regulation requires contracts**; contracts require a number; **research has not supplied a stable model**.
- **5% of contract value is not valuation** — it is a thumb rule that can under- or over-shoot real loss.
- **WTA is not WTP.** The paradox is that gap, not that people “don’t care.”
- This is **not** neoclassical rational man; it is **behavioural economics** (Kahneman): loss aversion and endowment.

- **Stated 5/5 on a survey is not revealed behaviour.** Contingent valuation exists because those two split.
- Privacy value is **context specific**; there is no all-weather unit price for a database.

Exam lines

- Why value privacy: controller–processor contracts, cloud, GDPR-style shared breach liability.
- Industry: **5% of contract value**; DPDP cap ₹500 crore as a guideline number.
- Gmail quiz: low pay-to-block-scan, high accept-to-allow-human-read → **privacy paradox**.
- Explain with **loss aversion** (pain, embarrassment, certainty over gambles) and **endowment** (trophy / 15-year inbox).
- Stated vs revealed preference; contingent valuation.
- Next case moves from the individual to **organisations trading private data**.

Lecture T40: Information Privacy — Economics and Strategy — Part 02

Learning focus

- Reconstruct the HBR discussion case The Dark Side of Custom Analytics (Davenport and Harris) as presented in class.
- Judge the proposed grocery–insurer data deal from **ShopSense** and **IFA** sides: money, law, trust, strategy.
- Separate **legal consent** in a loyalty programme from **ethical** use of grocery data to set health premiums.
- Contrast **Progressive**'s transparent driving logger with covert supermarket-to-insurer sharing.

Key terms

Term	Meaning in this lecture
Loyalty programme	Legal hook: customer consents to analytics in exchange for discounts
Scanner information	Item-level purchase data already traded without shopper knowledge
Personalised insurance	Premium/product fitted to **individual** behaviour (driving or grocery)
Legal vs ethical	No prohibiting statute ≠ no trust/relationship harm
Battered customer syndrome	After profiling, service concentrates on the top slice; the rest leave
Pilot / evidence-based deal	Trans-fat–claims correlation shown **before** the contract

Term	Meaning in this lecture
Exclusive data rights	IFA's hoped-for hurdle against rival insurers

Frameworks / formulas

	ShopSense	IFA
Gain	~$1B; already-paid analytics asset	Risk insight; new product; exclusive moat
Legal story	Loyalty T&Cs; state law silent	Insurers are expected to underwrite
Break	Loyalty opt-out; lost control; PR	Noisy household baskets; backlash; ethics

Distinctions

- **Legal in the United States at the time of the case** does not cancel an **ethical** and **relationship** problem.
- Loyalty consent for **analytics / coupons** is not the same, in customers' minds, as **selling to an insurer who raises premiums**.
- The customer is the **third party** whose data is traded while they are **not in the negotiation**.
- Purchase ≠ consumption; data has **noise**, but the pilot still found **real patterns**.
- This is not only a privacy case: it is **data as competitive strategy** (personalised product, exclusive rights).
- Free consumer apps that "do not charge" are in the same family: **data is the price**.

Exam lines

- ShopSense: loyalty + analytics + covert scanner sales; IFA wants grocery data to **personalise health premiums**.
- Legal in operating states then; **~$1B**; wellness spin; **trust, opt-out, loss of control** on the con side.
- Ethical core: **eating and drinking monitored by an insurer through a grocer**.
- Progressive = transparent personalised auto insurance; IFA path = same logic, weaker notice.
- Pilot correlation (trans fats ↔ claims) + exclusive data as **strategy**.
- Next session continues the case: trust survey, GDPR principles, RBV dependence, joint product.

Lecture T41: Information Privacy — Economics and Strategy — Part 03

Learning focus

- Use the **McKinsey 2019** confidence numbers to explain why retail trust is a **strategic** asset.
- Apply **purpose limitation, transparency, and data minimisation** to the ShopSense–IFA decision.
- Show why IFA's analytics strategy fails a strict **resource-based view** test (data not owned).
- Explain why **notice + old consent** is weak, and why a **joint product** is the smarter ethical design.

Key terms

Term	Meaning in this lecture
Purpose limitation	Use only for the disclosed collection purpose
Transparency	Customer say on external sharing; not selective disclosure
Data minimisation	Only necessary fields; deletable from one store
Selective disclosure	Organisations telling only convenient uses — drives low trust
RBV / VRIO	Strategy on valuable, rare, inimitable resources you **control**
Dependence / opportunism	Vendor can raise price or sell the same data to a rival
KBV	Insights/knowledge may be owned even if raw data is not; raw-material dependence remains
Joint product	Co-branded ShopSense–IFA insurance so sharing is visible in the offer
Attention problem	Notices exist; customers do not read them, so ethics are not fixed

Distinctions

- **Financial services look more trusted than retail** in McKinsey 2019; a grocer selling to an insurer is therefore **especially** dangerous for ShopSense.
- Disclosure as practised is often **selective**, which **is** the confidence problem.
- **Purpose limitation** forbids using coupon data to **set premiums**.
- **RBV fails** if the strategic resource is **rented**. KBV does not erase that dependence.
- The ethical scandal is not only misuse; it is that **the person is not in the deal**.
- **Legal consent + notices** already exist and **do not solve ethics**, because of **attention**.
- **Joint product** is offered as clearer than another T&C checkbox.

Exam lines

- ~10% retail data-handling confidence vs better healthcare/finance image.

- Three GDPR-style pointers: purpose, transparency, minimisation (and one-place deletion).
- Amazon: loyal customers charged **more**; sued; never throw data away.
- IFA strategy = differentiation on **un-owned** data → vendor opportunism.
- Customer absent from two-party trade = ethical core.
- Notices fail; **IFA–ShopSense insurance** as the design that puts the customer in the loop.
- Bridge to next class: **privacy as strategy** (Apple vs safety / Snowden).

Lecture T42: Privacy — Strategy and Safety — Part 01

Learning focus

- Recap why privacy is **individual, economic, and strategic**, then add **safety vs privacy**.
- Reconstruct **PRISM / Snowden** and the **Snowden effect** on Cisco, cloud, and "NSA-resistant" marketing.
- Walk Apple's encryption path: optional FDE → **default FDE (iOS 8)** → **iMessage E2E with no master key**.
- Compare **no encryption, E2E, key escrow, and split keys** as government-access designs.

Key terms

Term	Meaning in this lecture
Privacy vs safety	Capstone tension: E2E privacy vs national/victim justice
PRISM	NSA collection from firms, revealed 5 June 2013
MUSCULAR	NSA–UK joint collection
Snowden effect	Lost US tech sales, localisation, NSA-resistant marketing
FDE	Full disk encryption; default from iOS 8
Master key	What Apple claims **not** to have after passcode+device UID
CALEA	1994 US lawful intercept statute, later VoIP
Key escrow	Extra government-held key
Split keys / secret sharing	Several keys required in sequence

Distinctions

- Privacy is already **paradoxical and behavioural**; this case adds **state power** that does not play by the same law.
- Apple's stance looks **ideological** but must be read as **strategy** (developed in later parts).
- **Giving the US a special door** forces the same door for **repressive** states — or Apple becomes a **judge of countries**.
- **China audit** is already on the table as a **consistency** problem.

- Default encryption matters because **most people will never turn optional crypto on**, especially on slow Androids.
- "Apple cannot decrypt" is a **technical** claim that **shifts liability**, not only a slogan.

Exam lines

- Capstone: individual paradox + data trade ethics + **government as big brother**.
- Snowden/PRISM/MUSCULAR; hero vs traitor; industry **Snowden effect**.
- Cook's three dilemmas; Comey's unopenable safe; 6-digit passcode / 2FA / default crypto.
- iOS 8 default FDE; iMessage E2E; **no master key** (passcode + device-unique key).
- CALEA vs EU encryption policy; escrow vs split keys.
- Next: why governments want backdoors **now**, and Apple's **business model** versus Google's.

Lecture T43: Privacy — Strategy and Safety — Part 02

Learning focus

- Explain why default iOS 8 FDE changed **criminal investigation** (Manhattan DA: **74 of 92** phones dark).
- Separate **post-incident investigation** from **continuous government monitoring** (instructor's distinction).
- Compare **key-disclosure law**: US (no forced self-incrimination) vs UK/Australia vs **India IT Act s.69 (up to 7 years)**.
- Tie Apple's privacy **USP** to a business model that **does not sell ads**, and flag the **China data-centre** contradiction.

Key terms

Term	Meaning in this lecture
Default FDE effect	Lawful devices go dark (74 of 92)
Investigation vs monitoring	After a crime vs always-on collection/profiling
Five Eyes	US–UK–Canada–Australia–NZ SIGINT pact (1941)
TAO	NSA Tailored Access Operations
Key disclosure law	Whether you can be jailed for not decrypting
IT Act s.69	India: refuse to decrypt → up to 7 years (2008 amendment)
Escrow compromise	One stolen master key burns the whole corpus
Privacy USP	Marketing rating enabled by **not** living on ads
China audit	Local storage + alleged code review vs "no backdoor" claim

Frameworks / formulas

Jurisdiction	Can the state force the password?
US	No compelled self-incrimination; voluntary disclosure
UK, Australia	Yes, legally force key disclosure
India	s.69 IT Act: non-compliance up to **7 years**

Distinctions

- **74/92** is about **default** encryption, not about criminals being especially clever.
- **Safety after a death** is a serious argument; **Snowden-style bulk monitoring** is a **different** demand. Do not mix them.
- Government is **not God**; it is **partisan people**.
- A backdoor for "good" US agencies is a backdoor for **hostile regimes and hackers**.
- Apple "does not sell data" ≠ Apple "has no data." It has **cards and IDs**; it does not **monetise** them like Google.
- **China audit** undercuts a simple moral reading of the US encryption fight.

Exam lines

- iOS 8 default FDE: Manhattan **74 of 92** dark phones; Comey: unopenable evidence.
- Instructor split: **case investigation** vs **permanent monitoring**.
- US vs UK/Australia vs **India s.69 / 7 years**.
- Backdoor costs: dissidents, hackers, master-key leak, Greek parliament.
- Apple = devices revenue, privacy ratings; Google = ads; 400M iTunes records still held.
- China: in-country DC, audit, possible code share, Cook denial.
- Next: moral obligation, COVID apps, ATT, CSAM, San Bernardino.

Lecture T44: Privacy — Strategy and Safety — Part 03

Learning focus

- Use the **locker** metaphor to split **case-by-case opening** from a **permanent government key**.
- Compare **Apple–Google exposure notification** with **Aarogya Setu / StopCOVID** (location vs Bluetooth random IDs).
- Explain **ATT**, **CSAM neural hash**, and why Google's toddler-photo false alarm is the cautionary tale.
- Read Apple's privacy fights as **strategy**: San Bernardino, Israel crack, and **advertising share** versus Facebook/Google.

Key terms

Term	Meaning in this lecture
Locker metaphor	Customer holds the only key; Apple claims it cannot open
Case-by-case vs permanent	Fair opening of a dead user's device vs always-on spare key
Exposure notification	Bluetooth random IDs; no location; user-reported positive
StopCOVID / Aarogya Setu	State apps that wanted more location/control than Apple–Google
ATT	App Tracking Transparency — per-app tracking switch
CSAM	Child Sexual Abuse Material detection
Neural hash	Perceptual hash: same scene, same hash; unlike SHA-style file hash
Private set intersection	Match against CSAM DB without Apple learning non-matches
Threshold secret sharing	Do not decrypt/report until many hits; then humans review
San Bernardino	14 killed; Apple refused backdoor; FBI cracked via Israel

Frameworks / formulas

Move	Public story	Instructor's extra reading
Refuse FBI OS for one phone	Privacy principle	Also **protect the marketing position**
Exposure Notification	Privacy **and** health	Governments still wanted **location**
ATT	User transparency	**Shift digital ad share** to Apple
CSAM on-device hash	Middle ground	Threshold + humans vs Google's false positive

Distinctions

- **Culture and profit** explain Apple-in-China better than pure ethics.
- **Dead-user locker ≠ government spare key for every locker**. The case **mixes** them; unmix them.
- Aarogya Setu "open source" was **client only**; **server side closed** — that is the transparency gap.
- CSAM neural hash is **not** cryptographic file hashing; **on-device + threshold + manual review** is the privacy story; Google's toddler case is what you get **without** those brakes.
- San Bernardino: cooperate **for that case**; do **not** build a **permanent** door — and Apple still **lost face** when Israel cracked the phone.
- ATT is **privacy theatre and ad strategy at once**.
- Complete privacy would **end the ad industry**; that is a **hard reality**, not a slogan.

Exam lines

- Moral duty: culture + law of the land; Apple bends in China when profit is at risk.
- Locker: customer key; **fair** to open if the key died with the user; **unfair** permanent government key.
- Apple–Google: Bluetooth randoms, 14 days, no GPS/identity; France/India wanted more state control; fake reports; Aarogya Setu server not open.
- ATT → Facebook ~$10B; Apple also chasing **in-app ads**.
- CSAM: neural hash on device, NCMEC, PSI, threshold, manual review.
- San Bernardino 14 dead; Israel crack; encryption as **USP**; privacy vs safety remains an **open political** fight.

Lecture T45: Cyber Security and Privacy — Capstone Discussion A

Learning focus

- Stop treating **threat, attack, vulnerability, and risk** as synonyms; write **risk as residual risk**.
- Tune biometrics on the **FAR / FRR** trade-off; know why biometrics cannot be the only authenticator.
- Map blockchain **confidentiality, immutability, and non-repudiation** onto **encryption + hashing + private-key signature**.
- State the taught order for **ransomware**: **report** (DPDP / GDPR window), then restore operations (often **crypto** payment).

Key terms

Term	Meaning in this lecture
Threat	Source of risk
Attack	Point-in-time event
Vulnerability	Unplugged hole; what exploits target
Risk	State combining probability and impact; formula output is residual
Residual risk	Risk left after current measures
Loss frequency	f(P(threat), P(attack success))
Loss magnitude	From impact
FAR / FRR	False accept (false +) / false reject (false −)
Immutability	Hash as permanent transaction ID
Non-repudiation	Cannot deny you signed; private key / digital signature
Collision resistance	Hash property against two inputs, one digest (integrity)
DPDP reporting	Indian duty to report an incident in a set time

Distinctions

- **Risk ≠ threat ≠ attack ≠ vulnerability.** Risk is the **composite state**.
- **Always residual:** assessment does not re-count risk already covered by controls; that is why the extra “minus existing measures” term was **dropped**.

- Vulnerability is an **input to loss frequency**, not the whole of risk; **impact** still required.
- FAR and FRR **move opposite**; the meeting point still has **error** → biometrics **not sufficient alone**.
- Blockchain **security** here means **confidentiality from encryption**, not a vague "blockchain is safe."
- **Hash ≠ encryption.** Hash locks **integrity/immutability**; encryption locks **secrecy**; **private key** locks **who signed**.
- **Repudiation** is refusing the act; **non-repudiation** is a **system property**, not a moral hope.
- **Pay the ransomer only after reporting**; payment rail is often **crypto** because the thief chooses it.

Exam lines

- Threat sources risk; attack is an event; vulnerability is the hole; risk combines frequency, magnitude, uncertainty — **and is residual**.
- Banana peel / unpatched OS; TVA; P(success) depends on remaining holes.
- FAR up ⇔ FRR down; tune; never zero; not sole authentication.
- Blockchain: public-key confidentiality, hash immutability (and previous-hash links), private-key non-repudiation; collision resistance; skip algorithm trivia.
- Ransomware: **report under DPDP / GDPR (74h as taught)**, then pay if needed, often in cryptocurrency.
- Full DPDP–GDPR table comes in the privacy module / student discussions.

Lecture T46: Cyber Security and Privacy — Capstone Discussion B

Learning focus

- Define **insider** and **insider threat** (CISA and SEI) including **former staff** and **unwitting** harm.
- Separate **malicious, accidental, and negligent** insiders; list **motives** (money, grievance, ideology).
- Recognise **technical indicators** (odd hours, failed logins, exfiltration) and **controls** (SIEM, DLP, UEBA).
- Apply **routine activity, neutralization, and deterrence** theories to **policy violation**.
- Outline **NITF** programme building blocks: senior official, working group, policy, continuous training, programme office.

Key terms

Term	Meaning in this lecture
Insider	Has **or had** authorised access/knowledge of resources
Witting / unwitting	CISA: harm can be deliberate or not

Term	Meaning in this lecture
Malicious / accidental / negligent	Steal-or-destroy / careless / ignores policy
Compromised insider	Their **credentials** were taken (failed then successful login)
Exfiltration	Unauthorised data leaving the organisation
Routine activity	Offender + target + **no guardian**
Neutralization	Talking yourself into the violation
Deterrence	Benefit vs certainty/severity/speed of punishment
SIEM / DLP / UEBA	Correlate logs / block leaks / score behaviour
NITF	US model for an insider-threat **programme**, not a gadget

Exam lines

- Insider = authorised access **now or in the past**; threat = use of that access to harm, **on purpose or not**.
- Types: malicious, accidental, negligent. Motives: **money, grievance, ideology** (Verizon DBIR).
- Snowden (contractor, no behaviour monitoring); Tesla 2023 leavers and 75k HR rows — **joiners and leavers**.
- Watch 2 a.m. logins, priv-esc, USB dumps; detect with SIEM, DLP, UEBA.
- Theories: routine activity, neutralization (Sykes & Matza), deterrence.
- NITF: named official, cross-functional group, policy, **ongoing** awareness, office that updates rules.
- Culture + monitoring + tech together; one insider can still take the firm down.
